

SIMATS ENGINEERING

ASSESSMENT TOOL 1

COURSE NAME: Ethical Hacking

COURSE CODE: ITA1407

COURSE OUTCOME COVERED

CO4: Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux.

Question 1: Web Server Reconnaissance and Vulnerability Analysis

A cybersecurity analyst is assigned an authorized and isolated vulnerable web server for a security assessment. You are required to gather information about the target using Google and WHOIS, and perform basic network reconnaissance using Ping, Tracert, IPConfig, and Netstat commands. Use Nmap to identify open ports, running services, and service versions. Use WhatWeb to identify the web technologies and frameworks used by the server. Examine HTTP response headers using Curl/Wget and identify information disclosure. Perform CGI and web-server vulnerability scanning using Nikto, and use Gobuster/Dirb to discover hidden directories and files. Analyze the identified administrative pages, backup files, configuration files, and vulnerable resources. Finally, classify the findings based on severity and impact, and recommend appropriate web-server hardening and information-disclosure prevention measures. Submit the commands executed, screenshots, observations, findings, and recommendations.

COMMANDS AND OUTPUT:

1. ping -c 4 127.0.0.1

```
(kali㉿kali)-[~]
$ ping -c 4 127.0.0.1
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=1.81 ms
64 bytes from 127.0.0.1: icmp_seq=2 ttl=64 time=0.050 ms
64 bytes from 127.0.0.1: icmp_seq=3 ttl=64 time=0.048 ms
64 bytes from 127.0.0.1: icmp_seq=4 ttl=64 time=0.046 ms

— 127.0.0.1 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3046ms
rtt min/avg/max/mdev = 0.046/0.487/1.806/0.761 ms
```

2. traceroute 127.0.0.1

```
(kali㉿kali)-[~]
$ traceroute 127.0.0.1
traceroute to 127.0.0.1 (127.0.0.1), 30 hops max, 60 byte packets
 1 localhost (127.0.0.1)  0.206 ms  0.176 ms  0.166 ms
```

3. ip addr

```
(kali㉿kali)-[~]
$ ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
   inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 08:00:27:5a:87:bc brd ff:ff:ff:ff:ff:ff
   inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
       valid_lft 85690sec preferred_lft 85690sec
   inet6 fd17:625c:f037:2:50f0:f698:66ab:20d5/64 scope global dynamic noprefixroute
       valid_lft 85933sec preferred_lft 13933sec
   inet6 fe80::e98b:3c40:9f97:8af0/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```

4. ss -tulnp

```
(kali㉿kali)-[~]
$ ss -tulnp
Netid      State      Recv-Q     Send-Q     Local Address:Port    Peer Address:Port    Process
tcp        LISTEN     0           511        *:80                 *:*                   *
```

5. nmap -sV -sC 127.0.0.1

```
(kali@kali)-[~]
$ nmap -sV -sC 127.0.0.1
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-18 23:21 -0400
Nmap scan report for localhost (127.0.0.1)
Host is up (0.0000040s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.68 ((Debian))
|_http-title: Apache2 Debian Default Page: It works
|_http-server-header: Apache/2.4.68 (Debian)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.14 seconds
```

6. whatweb <http://127.0.0.1>

```
(kali@kali)-[~]
$ whatweb http://127.0.0.1
http://127.0.0.1 [200 OK] Apache[2.4.68], Country[RESERVED][XX], HTTPServer[Debian Linux][Apache/2.4.68 (Debian)], IP[127.0.0.1], Title[Apache2 Debian Default Page: It works]
```

7. curl -I <http://127.0.0.1>

```
(kali@kali)-[~]
$ curl -i http://127.0.0.1
HTTP/1.1 200 OK
Date: Wed, 19 Aug 2026 03:22:57 GMT
Server: Apache/2.4.68 (Debian)
Last-Modified: Tue, 16 Jun 2026 14:30:02 GMT
ETag: "29cf-6545fc74d1156"
Accept-Ranges: bytes
Content-Length: 10703
Vary: Accept-Encoding
Content-Type: text/html

<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">
<html xmlns="http://www.w3.org/1999/xhtml">
  <head>
    <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
    <title>Apache2 Debian Default Page: It works</title>
    <style type="text/css" media="screen">
      * {
        margin: 0px 0px 0px 0px;
        padding: 0px 0px 0px 0px;
      }

      body, html {
        padding: 3px 3px 3px 3px;

        background-color: #D8DBE2;

        font-family: Verdana, sans-serif;
        font-size: 11pt;
        text-align: center;
      }

      div.main_page {
        position: relative;
        display: table;

        width: 800px;

        margin-bottom: 3px;
        margin-left: auto;
        margin-right: auto;
        padding: 0px 0px 0px 0px;

        border-width: 2px;
        border-color: #212738;
        border-style: solid;

        background-color: #FFFFFF;
```

8. `wget -S --spider http://127.0.0.1`

```
(kali㉿kali)-[~]
$ wget -S --spider http://127.0.0.1
Spider mode enabled. Check if remote file exists.
--2026-08-18 23:24:34-- http://127.0.0.1/
Connecting to 127.0.0.1:80... connected.
HTTP request sent, awaiting response...
HTTP/1.1 200 OK
Date: Wed, 19 Aug 2026 03:24:34 GMT
Server: Apache/2.4.68 (Debian)
Last-Modified: Tue, 16 Jun 2026 14:30:02 GMT
ETag: "29cf-6545fc74d1156"
Accept-Ranges: bytes
Content-Length: 10703
Vary: Accept-Encoding
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html
Length: 10703 (10K) [text/html]
Remote file exists and could contain further links,
but recursion is disabled -- not retrieving.
```

9. `nikto -h http://127.0.0.1`

```
(kali㉿kali)-[~]
$ nikto -h http://127.0.0.1
- Nikto v2.6.0

+ Target IP: 127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port: 80
+ Platform: Linux/Unix
+ Start Time: 2026-08-18 23:25:00 (GMT-4)

+ Server: Apache/2.4.68 (Debian)
+ ERROR: Failed to check for updates: 403
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999984] /: Server may leak inodes via ETags, header found with file /, inode: 29cf, size: 6545fc74d1156, mtime: gzip. See: https://cve.mitre.org/cgi-b
in/cvename.cgi?name=CVE-2003-1418
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transpo
rt-Security
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Op
tions
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [999990] OPTIONS: Allowed HTTP Methods: HEAD, GET, POST, OPTIONS
+ [001406] /server-status: The mod_status module reveals Apache information. See: https://httpd.apache.org/docs/2.4/mod/mod_status.html
```

10. gobuster dir -u http://127.0.0.1 -w /usr/share/wordlists/dirb/common.txt

```
(kali㉿kali)-[~]
$ gobuster dir -u http://127.0.0.1 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://127.0.0.1
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.hta (Status: 403) [Size: 314]
.htpasswd (Status: 403) [Size: 314]
.htaccess (Status: 403) [Size: 314]
index.html (Status: 200) [Size: 10703]
javascript (Status: 301) [Size: 351] [→ http://127.0.0.1/javascript/]
server-status (Status: 200) [Size: 4386]
Progress: 4613 / 4613 (100.00%)

Finished
```

11. dirb <http://127.0.0.1>

```
(kali㉿kali)-[~]
$ dirb http://127.0.0.1

DIRB v2.22
By The Dark Raver

START_TIME: Tue Aug 18 23:26:59 2026
URL_BASE: http://127.0.0.1/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

--- Scanning URL: http://127.0.0.1/ ---
+ http://127.0.0.1/index.html (CODE:200|SIZE:10703)
=> DIRECTORY: http://127.0.0.1/javascript/
+ http://127.0.0.1/server-status (CODE:200|SIZE:6063)

--- Entering directory: http://127.0.0.1/javascript/ ---
=> DIRECTORY: http://127.0.0.1/javascript/jquery/

--- Entering directory: http://127.0.0.1/javascript/jquery/ ---
+ http://127.0.0.1/javascript/jquery/jquery (CODE:200|SIZE:285284)

END_TIME: Tue Aug 18 23:27:01 2026
DOWNLOADED: 13836 - FOUND: 3
```

Question 2: Web Application Vulnerability Assessment

A cybersecurity analyst is assigned an authorized vulnerable web application in an isolated laboratory environment for security testing. You are required to identify the application's technologies and attack surface using appropriate reconnaissance techniques, examine input fields, parameters, cookies, sessions, and HTTP requests, and use suitable tools to identify vulnerabilities such as SQL Injection, Cross-Site Scripting (XSS), insecure authentication, session-management weaknesses, directory traversal, and security misconfigurations. Use tools such as Burp Suite, OWASP ZAP, Nikto, Nmap, Curl, and browser developer tools to analyze the application. Test the identified vulnerabilities only within the authorized laboratory environment, document the evidence and potential impact of each finding, classify the vulnerabilities according to severity, and recommend appropriate remediation and secure coding practices. Submit the commands/tool configurations, screenshots, observations, vulnerability findings, severity ratings, impacts, and recommendations.

COMMANDS AND OUTPUT:

1. nmap -sV -sC 127.0.0.1

```
(kali@kali)-[~]
└─$ nmap -sV 127.0.0.1
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-18 23:41 -0400
Nmap scan report for localhost (127.0.0.1)
Host is up (0.0000030s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.68 ((Debian))

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.94 seconds

(kali@kali)-[~]
└─$ whatweb http://127.0.0.1/dvwa
http://127.0.0.1/dvwa [404 Not Found] Apache[2.4.68], Country[RESERVED][22], HTTPServer[Debian Linux][Apache/2.4.68 (Debian)], IP[127.0.0.1], Title[404 Not Found]
```

2. whatweb <http://127.0.0.1/dvwa>

```
(kali@kali)-[~]
└─$ whatweb http://127.0.0.1/dvwa
http://127.0.0.1/dvwa [404 Not Found] Apache[2.4.68], Country[RESERVED][22], HTTPServer[Debian Linux][Apache/2.4.68 (Debian)], IP[127.0.0.1], Title[404 Not Found]
```

3. curl -i <http://127.0.0.1/dvwa>

```
(kali㉿kali)-[~]
$ curl -i http://127.0.0.1/dvwa
HTTP/1.1 404 Not Found
Date: Wed, 19 Aug 2026 03:42:35 GMT
Server: Apache/2.4.68 (Debian)
Content-Length: 311
Content-Type: text/html; charset=iso-8859-1

<!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN" "http://www.w3.org/TR/html4/strict.dtd">
<html><head>
<title>404 Not Found</title>
</head><body>
<h1>Not Found</h1>
<p>The requested URL was not found on this server.</p>
<hr>
<address>Apache/2.4.68 (Debian) Server at 127.0.0.1 Port 80</address>
</body></html>
```

4. curl -I <http://127.0.0.1/dvwa>

```
(kali㉿kali)-[~]
$ curl -I http://127.0.0.1/dvwa
HTTP/1.1 404 Not Found
Date: Wed, 19 Aug 2026 03:43:01 GMT
Server: Apache/2.4.68 (Debian)
Content-Type: text/html; charset=iso-8859-1
```

5. nikto -h <http://127.0.0.1/dvwa>

```
(kali㉿kali)-[~]
$ nikto -h http://127.0.0.1/dvwa
- Nikto v2.6.0

+ Target IP: 127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port: 80
+ Platform: Linux/Unix
+ Start Time: 2026-08-18 23:43:20 (GMT-4)

+ Server: Apache/2.4.68 (Debian)
+ ERROR: Failed to check for updates: 403
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI
+ [013587] /dvwa/: Suggested security header missing: strict-transport-security.
transport-Security
+ [013587] /dvwa/: Suggested security header missing: content-security-policy. S
+ [013587] /dvwa/: Suggested security header missing: x-content-type-options. Se
pe-Options
+ [013587] /dvwa/: Suggested security header missing: permissions-policy. See: h
cy
+ [013587] /dvwa/: Suggested security header missing: referrer-policy. See: http
+ [000000] OPTIONS: Allowed HTTP Methods: HEAD, GET, POST, OPTIONS
```


6. `wget --server-response --spider http://127.0.0.1/dvwa`

```
(kali@kali)-[~]
$ nikto -h http://127.0.0.1/dvwa
- Nikto v2.6.0

+ Target IP: 127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port: 80
+ Platform: Linux/Unix
+ Start Time: 2026-08-18 23:43:20 (GMT-4)

+ Server: Apache/2.4.68 (Debian)
+ ERROR: Failed to check for updates: 403
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [013587] /dvwa/: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /dvwa/: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /dvwa/: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /dvwa/: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /dvwa/: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [999990] OPTIONS: Allowed HTTP Methods: HEAD, GET, POST, OPTIONS .
```

7. `gobuster dir -u http://127.0.0.1/dvwa -w /usr/share/wordlists/dirb/common.txt`

```
(kali@kali)-[~]
$ gobuster dir -u http://127.0.0.1/dvwa -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://127.0.0.1/dvwa
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

Progress: 4613 / 4613 (100.00%)

Finished
```

Question 3: Security Header and HTTPS Configuration Assessment

A cybersecurity analyst is assigned an authorized web application hosted in an isolated laboratory environment to assess its HTTPS and security-header configuration. You are required to use Curl to examine HTTP response headers and Nmap SSL scripts to analyze the server's HTTPS/TLS configuration. Identify missing or improperly configured security headers such as Content-Security-Policy (CSP), HSTS, X-Frame-Options, and X-Content-Type-Options, and verify whether HTTP requests are automatically redirected to HTTPS. Examine the TLS configuration for weak protocols, insecure cipher suites, and certificate-related issues. Analyze the security purpose and potential impact of each misconfiguration, classify the findings according to their severity, and recommend appropriate HTTPS, TLS, certificate, and security-header hardening measures. Submit the commands used, screenshots, observations, identified risks, severity classification, and remediation recommendations.

COMMANDS AND OUTPUT:

1. `sudo systemctl status apache2 --no-pager`

```
(kali@kali)-[~]
$ sudo systemctl status apache2 --no-pager
● apache2.service - The Apache HTTP Server
   Loaded: loaded (/usr/lib/systemd/system/apache2.service; disabled; preset: disabled)
   Active: active (running) since Wed 2026-08-19 01:12:45 EDT; 28s ago
     Invocation: fdf0579895464185b2bf367a1eda0555
       Docs: https://httpd.apache.org/docs/2.4/
    Main PID: 3889 (apache2)
      Status: "Total requests: 0; Idle/Busy workers 100/0; Requests/sec: 0; Bytes served/sec: 0 B/sec"
        Tasks: 6 (limit: 2132)
       Memory: 21.4M (peak: 21.7M)
          CPU: 294ms
    CGroup: /system.slice/apache2.service
            └─3889 /usr/sbin/apache2 -k start -DFOREGROUND
              └─3913 /usr/sbin/apache2 -k start -DFOREGROUND
                └─3914 /usr/sbin/apache2 -k start -DFOREGROUND
                  └─3916 /usr/sbin/apache2 -k start -DFOREGROUND
                    └─3917 /usr/sbin/apache2 -k start -DFOREGROUND
                      └─3918 /usr/sbin/apache2 -k start -DFOREGROUND

Aug 19 01:12:44 kali systemd[1]: Starting apache2.service - The Apache HTTP Server...
Aug 19 01:12:45 kali apache2ctl[3889]: AH00558: apache2: Could not reliably determine the server's fully qualified domain name, using 127.0.0.1...his message
Aug 19 01:12:45 kali systemd[1]: Started apache2.service - The Apache HTTP Server.
Hint: Some lines were ellipsized, use -l to show in full.
```

2. `curl -I http://127.0.0.1`

```
(kali@kali)-[~]
$ curl -I http://127.0.0.1
Command 'curl' not found, did you mean:
  command 'cut' from deb coreutils
  command 'curl' from deb curl
  command 'outl' from deb ioprt
Try: sudo apt install <deb name>
```

3. `curl -i http://127.0.0.1`

```
(kali@kali)-[~]
$ curl -i http://127.0.0.1
HTTP/1.1 200 OK
Date: Wed, 19 Aug 2026 05:14:08 GMT
Server: Apache/2.4.68 (Debian)
Last-Modified: Tue, 16 Jun 2026 14:30:02 GMT
ETag: "29cf6545fc74d1156"
Accept-Ranges: bytes
Content-Length: 10703
Vary: Accept-Encoding
Content-Type: text/html

<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">
<html xmlns="http://www.w3.org/1999/xhtml">
  <head>
    <meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />
    <title>Apache2 Debian Default Page: It works</title>
    <style type="text/css" media="screen">
      * {
        margin: 0px 0px 0px 0px;
        padding: 0px 0px 0px 0px;
      }
    </style>
  </head>
  <body, html {
    padding: 3px 3px 3px 3px;
    background-color: #D8DBE2;
    font-family: Verdana, sans-serif;
    font-size: 11pt;
    text-align: center;
  }
  </body>
  <div.main_page {
    position: relative;
    display: table;
    width: 800px;
    margin-bottom: 3px;
    margin-left: auto;
    margin-right: auto;
    padding: 0px 0px 0px 0px;
    border-width: 2px;
    border-color: #212738;
    border-style: solid;
```

4. curl -k -I <http://127.0.0.1>

```
(kali㉿kali)-[~]  
$ curl -k -I http://127.0.0.1  
Command 'curl' not found, did you mean:  
  command 'cutl' from deb curl  
  command 'outl' from deb ioport  
  command 'cut' from deb coreutils  
Try: sudo apt install <deb name>
```

5. curl -I <http://127.0.0.1>

```
(kali㉿kali)-[~]  
$ curl -I http://127.0.0.1  
HTTP/1.1 200 OK  
Date: Wed, 19 Aug 2026 05:14:36 GMT  
Server: Apache/2.4.68 (Debian)  
Last-Modified: Tue, 16 Jun 2026 14:30:02 GMT  
ETag: "29cf-6545fc74d1156"  
Accept-Ranges: bytes  
Content-Length: 10703  
Vary: Accept-Encoding  
Content-Type: text/html
```

6. nmap -p 443 --script ssl-enum-ciphers 127.0.0.1

```
(kali㉿kali)-[~]  
$ nmap -p 443 --script ssl-cert 127.0.0.1  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-19 01:15 -0400  
Nmap scan report for localhost (127.0.0.1)  
Host is up (0.00051s latency).  
  
PORT      STATE SERVICE  
443/tcp   closed https  
  
Nmap done: 1 IP address (1 host up) scanned in 0.21 seconds
```

7. nmap -p 443 --script ssl-enum,ssl-enum-ciphers 127.0.0.1

```
(kali㉿kali)-[~]  
$ nmap -p 443 --script ssl-cert,ssl-enum-ciphers 127.0.0.1  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-19 01:16 -0400  
Nmap scan report for localhost (127.0.0.1)  
Host is up (0.00018s latency).  
  
PORT      STATE SERVICE  
443/tcp   closed https  
  
Nmap done: 1 IP address (1 host up) scanned in 0.21 seconds
```

Question 4: Broken Access-Control Assessment

A cybersecurity analyst is assigned an authorized student portal in an isolated laboratory environment containing separate student and administrator test accounts. Using OWASP ZAP, capture and analyze requests generated while accessing student records and identify test object identifiers in URLs, forms, cookies, or API requests. Using only the test identifiers provided by the faculty, determine whether one student account can access another student's records or whether a normal user can directly access administrator-only resources. Compare the server responses for authorized and unauthorized requests, explain the difference between authentication and authorization failures, classify the identified access-control weaknesses based on their severity and impact, and recommend appropriate server-side authorization checks, role validation, and secure object-reference mechanisms. Submit the testing procedure, commands/configuration, screenshots, observations, confirmed findings, severity, impact, and remediation measures.

COMMANDS AND OUTPUT:

1. `sudo systemctl start apache2`

```
(kali㉿kali)-[~]  
$ sudo systemctl start apache2  
[sudo] password for kali:
```

2. `curl -I http://127.0.0.1`

```
(kali㉿kali)-[~]  
$ curl -I http://127.0.0.1  
HTTP/1.1 200 OK  
Date: Wed, 19 Aug 2026 14:06:03 GMT  
Server: Apache/2.4.68 (Debian)  
Last-Modified: Tue, 16 Jun 2026 14:30:02 GMT  
ETag: "29cf-6545fc74d1156"  
Accept-Ranges: bytes  
Content-Length: 10703  
Vary: Accept-Encoding  
Content-Type: text/html
```

3. nmap -p 80,443,8080,8000,8443 -sV 127.0.0.1

```
(kali@kali)-[~]
$ nmap -p 80,443,8080,8000,8443 -sV 127.0.0.1
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-19 10:06 -0400
Nmap scan report for localhost (127.0.0.1)
Host is up (0.0014s latency).

PORT      STATE SERVICE      VERSION
80/tcp    open  http        Apache httpd 2.4.68 ((Debian))
443/tcp   closed https
8000/tcp  closed http-alt
8080/tcp  closed http-proxy
8443/tcp  closed https-alt

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.87 seconds
```

4. burpsuite

```
(kali@kali)-[~]
$ burpsuite
[warning] /usr/bin/burpsuite: No JAVA_CMD set for run_java, falling back to JAVA_CMD = java
WARNING: A terminally deprecated method in sun.misc.Unsafe has been called
WARNING: sun.misc.Unsafe::objectFieldOffset has been called by io.opentelemetry.internal.shaded.jctools.util.UnsafeAccess (file:/usr/share/burpsuite/burp
suite.jar)
WARNING: Please consider reporting this to the maintainers of class io.opentelemetry.internal.shaded.jctools.util.UnsafeAccess
WARNING: sun.misc.Unsafe::objectFieldOffset will be removed in a future release
```

Question 5: Automated Scanning and Manual Validation

A cybersecurity analyst is assigned an authorized web application hosted in a controlled cybersecurity laboratory for vulnerability assessment. Use Nikto to identify web-server misconfigurations and outdated components, and use Wapiti or OWASP ZAP to perform an automated web-application security scan. Compare the vulnerabilities reported by the selected tools and categorize them into misconfiguration, information disclosure, authentication, and injection issues. Select at least three findings for safe manual validation within the authorized laboratory environment and determine whether each finding is confirmed, a false positive, or requires further investigation. Assign an appropriate severity level based on likelihood and potential impact, and recommend practical remediation measures for all confirmed vulnerabilities. Submit a comparative report containing tool outputs, screenshots, validation evidence, severity classification, remediation measures, and overall conclusions.

COMMANDS AND OUTPUT:

1. `sudo systemctl start apache2`

```
(kali㉿kali)-[~]  
$ sudo systemctl start apache2
```

2. `curl -I http://127.0.0.1`

```
(kali㉿kali)-[~]  
$ curl -I http://127.0.0.1  
HTTP/1.1 200 OK  
Date: Wed, 19 Aug 2026 14:19:59 GMT  
Server: Apache/2.4.68 (Debian)  
Last-Modified: Tue, 16 Jun 2026 14:30:02 GMT  
ETag: "29cf-6545fc74d1156"  
Accept-Ranges: bytes  
Content-Length: 10703  
Vary: Accept-Encoding  
Content-Type: text/html
```

3. `nmap -sV 127.0.0.1`

```
(kali㉿kali)-[~]  
$ nmap -sV 127.0.0.1  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-19 10:20 -0400  
Nmap scan report for localhost (127.0.0.1)  
Host is up (0.0000040s latency).  
Not shown: 999 closed tcp ports (reset)  
PORT      STATE SERVICE VERSION  
80/tcp open  http    Apache httpd 2.4.68 ((Debian))  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 6.52 seconds
```

4. `nikto -h http://127.0.0.1`

```
(kali㉿kali)-[~]  
$ nikto -h http://127.0.0.1  
- Nikto v2.6.0  
  
+ Target IP: 127.0.0.1  
+ Target Hostname: 127.0.0.1  
+ Target Port: 80  
+ Platform: Linux/Unix  
+ Start Time: 2026-08-19 10:20:59 (GMT-4)  
  
+ Server: Apache/2.4.68 (Debian)  
+ ERROR: Failed to check for updates: 403  
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.  
+ [999984] /: Server may leak inodes via ETags, header found with file /, inode: 29cf, size: 6545fc74d1156, mtime: gzip. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418  
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options  
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP  
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security  
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy  
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy  
+ [999990] OPTIONS: Allowed HTTP Methods: GET, POST, OPTIONS, HEAD .  
+ [001406] /server-status: The mod_status module reveals Apache information. See: https://httpd.apache.org/docs/2.4/mod/mod\_status.html
```

5. wapiti -u <http://127.0.0.1>

```
(kali@kali)-[~]
$ wapiti -u http://127.0.0.1

Wapiti 3.2.10 (wapiti-scanner.github.io)
X-Frame-Options is not set on http://127.0.0.1/
X-Content-Type-Options is not set on http://127.0.0.1/
CSP is not set for URL: http://127.0.0.1/
Host 127.0.0.1 serves HTTP content without redirecting to HTTPS.
Potential full path disclosure in http://127.0.0.1/: /var/www/html/index.html
Potential full path disclosure in http://127.0.0.1/: /usr/share/doc/apache2/README.Debian.gz
Potential full path disclosure in http://127.0.0.1/: /etc/apache2/
Potential full path disclosure in http://127.0.0.1/: /etc/init.d/apache2
Potential full path disclosure in http://127.0.0.1/: /usr/bin/apache2
Potential full path disclosure in http://127.0.0.1/: /var/www
Potential full path disclosure in http://127.0.0.1/: /usr/share
Potential full path disclosure in http://127.0.0.1/: /etc/apache2/apache2.conf
Potential full path disclosure in http://127.0.0.1/: /var/www/html
[*] Saving scan state, please wait ...
This scan has been saved in the file /home/kali/.wapiti/scans/127.0.0.1_folder_d5541dbe.db
[*] Wapiti found 2 URLs and forms during the scan

[*] Launching module redirect

[*] Launching module ssrf
[*] Asking endpoint URL https://wapiti3.ovh/get_ssrf.php?session_id=5kos0m for results, please wait ...

[*] Launching module exec

[*] Launching module file

[*] Launching module sql

[*] Launching module upload

[*] Launching module ssl

[*] Launching module xss

[*] Launching module permanentxss

[*] Generating report ...
A report has been generated in the file /home/kali/.wapiti/generated_report
Open /home/kali/.wapiti/generated_report/127.0.0.1_08192026_1421.html with a browser to see this report.
```

6. gobuster dir -u <http://127.0.0.1> -w /usr/share/wordlists/dirb/common.txt

```
(kali@kali)-[~]
$ gobuster dir -u http://127.0.0.1 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://127.0.0.1
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.hta (Status: 403) [Size: 314]
.htpasswd (Status: 403) [Size: 314]
.htaccess (Status: 403) [Size: 314]
index.html (Status: 200) [Size: 10703]
javascript (Status: 301) [Size: 351] [→ http://127.0.0.1/javascript/]
server-status (Status: 200) [Size: 4655]
Progress: 4613 / 4613 (100.00%)

Finished
```


7. nikto -h http://127.0.0.1 -o nikto.txt

```
(kali@kali)-[~]
$ nikto -h http://127.0.0.1 -o nikto.txt
- Nikto v2.6.0

+ Target IP: 127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port: 80
+ Platform: Linux/Unix
+ Start Time: 2026-08-19 10:38:49 (GMT-4)

+ Server: Apache/2.4.68 (Debian)
+ ERROR: Failed to check for updates: 403
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999984] /: Server may leak inodes via ETags, header found with file /, inode: 29cf, size: 6545fc74d1156, mtime: gzip. See: https://cve.mitre.org/cgi-b
in/cvename.cgi?name=CVE-2003-1418
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transpo
rt-Security
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Op
tions
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [999990] OPTIONS: Allowed HTTP Methods: GET, POST, OPTIONS, HEAD .
+ [001406] /server-status: The mod_status module reveals Apache information. See: https://httpd.apache.org/docs/2.4/mod/mod_status.html
```

8. wapiti -u http://127.0.0.1 -f html -o wapiti.html

```
(kali@kali)-[~]
$ nikto -h http://127.0.0.1 -f html -o wapiti.html
- Nikto v2.6.0

+ Target IP: 127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port: 80
+ Platform: Linux/Unix
+ Start Time: 2026-08-19 10:26:00 (GMT-4)

+ Server: Apache/2.4.68 (Debian)
+ ERROR: Failed to check for updates: 403
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999984] /: Server may leak inodes via ETags, header found with file /, inode: 29cf, size: 6545fc74d1156, mtime: gzip. See: https://cve.mitre.org/cgi-b
in/cvename.cgi?name=CVE-2003-1418
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transpo
rt-Security
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Op
tions
+ [999990] OPTIONS: Allowed HTTP Methods: GET, POST, OPTIONS, HEAD .
+ [001406] /server-status: The mod_status module reveals Apache information. See: https://httpd.apache.org/docs/2.4/mod/mod_status.html
```

9. curl -I http://127.0.0.1

```
(kali@kali)-[~]
$ curl -I http://127.0.0.1
HTTP/1.1 200 OK
Date: Wed, 19 Aug 2026 14:27:20 GMT
Server: Apache/2.4.68 (Debian)
Last-Modified: Tue, 16 Jun 2026 14:30:02 GMT
ETag: "29cf-6545fc74d1156"
Accept-Ranges: bytes
Content-Length: 10703
Vary: Accept-Encoding
Content-Type: text/html
```